

Fire Crow Audit Report

Continuous Offensive Security & SAST Agent Analysis

Job ID:	job-vuln
Repository URL:	https://github.com/example/vulnerable-app
Branch:	main
Audit Date:	June 07, 2026
Total Findings:	5

Executive Summary

OVERALL POSTURE: CRITICAL RISK

Fire Crow completed an authorization-only defensive security review of the submitted repository and recorded evidence-backed findings from the configured scanners.

2

CRITICAL

2

HIGH

1

MEDIUM

0

LOW

Summary Table of Findings

ID	Title	Severity	Source	CWE
FC-001	[SIMULATED] SQL Injection in user profile parameters	CRITICAL	DYNAMIC_ATTACK_SQLMAP	CWE-89
FC-002	[SIMULATED] Outdated Web Component Vulnerability	HIGH	DYNAMIC_ATTACK_NUCLEI	CWE-1395
FC-003	[SIMULATED] Outdated dependency with known CVE	MEDIUM	DEPENDENCY_SCAN	CWE-200
FC-004	[SIMULATED] Hardcoded Secret or Insecure Deserialization	HIGH	SEMGREP	CWE-502
FC-005	[SIMULATED] SQL Injection Validation Evidence	CRITICAL	EXPLOIT_VERIFIER	CWE-89

Scanner Execution Evidence

Scanner	Status	Mode	Tool
Recon	executed	simulated	git
Regex SAST	executed	regex	built-in regex
Semgrep	executed	simulated	semgrep
Dependency scan	executed	simulated	osv-scanner/trivy
Dynamic validation	executed	simulated	sqlmap/nuclei
Sandbox mode	executed	simulation	docker

Detailed Findings & Proofs

FC-001 [SIMULATED] SQL Injection in user profile parameters

CRITICAL

Source Agent: DYNAMIC_ATTACK_SQLMAP | CWE Link: [CWE-89](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Controlled sandbox validation confirmed SQL injection behavior on the generated sandbox target. Query parameter 'id' was modified during an authorization-only audit.

Evidence Sample

```
scanner_name=sqlmap; scanner_mode=simulated; confidence=high  
[INFO] POST parameter 'username' is vulnerable to SQL injection (DBMS: SQLite)
```

REMEDIATION GUIDANCE

Ensure database queries use parameterized queries or ORM bindings rather than string interpolation.

FC-002 [SIMULATED] Outdated Web Component Vulnerability

HIGH

Source Agent: DYNAMIC_ATTACK_NUCLEI | CWE Link: [CWE-1395](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Controlled sandbox validation detected a high-severity CVE signature on the generated sandbox target.

Evidence Sample

```
scanner_name=nuclei; scanner_mode=simulated; confidence=medium  
[CVE-2021-44228] Critical Apache Log4j RCE vulnerability detected
```

REMEDIATION GUIDANCE

Patch packages and update system libraries in Docker runtime environment.

FC-003 [SIMULATED] Outdated dependency with known CVE

MEDIUM

Source Agent: DEPENDENCY_SCAN | CWE Link: [CWE-200](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Debug-mode simulated dependency finding. Production reports only include dependency findings from configured scanners such as osv-scanner or trivy.

Evidence Sample

```
scanner_name=dependency-simulation; scanner_mode=simulated; confidence=low  
package=requests; version=2.28.1
```

REMEDIATION GUIDANCE

Follow standard secure coding patterns, validate all entry points, and sanitise parameters.

FC-004 [SIMULATED] Hardcoded Secret or Insecure Deserialization

HIGH

Source Agent: SEMGREP | CWE Link: [CWE-502](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Debug-mode simulated Semgrep finding. Production reports only include Semgrep findings when the semgrep CLI executes successfully.

Evidence Sample

```
scanner_name=semgrep-simulation; scanner_mode=simulated; confidence=low  
rule_id=debug.simulated.yaml-load
```

REMEDIATION GUIDANCE

Review the affected code and apply standard security best practices to mitigate this vulnerability.

FC-005 [SIMULATED] SQL Injection Validation Evidence

CRITICAL

Source Agent: EXPLOIT_VERIFIER | CWE Link: [CWE-89](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Controlled sandbox validation confirmed SQL injection behavior and collected bounded evidence.

Evidence Sample

```
scanner_name=sqlmap; scanner_mode=simulated; confidence=high
Retrieved available databases: [redacted sample]
Output Sample:
[INFO] POST parameter 'username' is vulnerable to SQL injection (DBMS: SQLite)
```

REMEDIATION GUIDANCE

Remediate parameter validation layers immediately to block statement concatenation.